TECHNICAL ASSESSMENT / CONTROLLED LAB

Metasploitable 2
Network Service Assessment

Evidence-based penetration test notes and validated findings

Assessment detail	Value
Assessment host	192.168.107.165 (Metasploitable 2)
Testing workstation	192.168.107.168 (Kali Linux)
Assessment date	19 October 2026 (some supporting exploitation evidence dated 18 October 2026)
Assessor	CyberSingh
Environment	Private, isolated, intentionally vulnerable training VMs
Coverage	Network services demonstrated in the supplied evidence only
Report version	1.1 — revised technical presentation

Purpose of this document

This is a portfolio-ready record of a practical assessment against an intentionally vulnerable lab host. It is not represented as a client-authorized production penetration test. Statements are limited to the supplied terminal captures and visible application output.

Evidence statement

The screenshots on the following pages are from the practical exercises. The report does not substitute a successful session where one was not shown, does not assume credentials not visible on-screen, and does not treat a service banner as proof of exploitability.

1. Engagement summary

The assessment uncovered several direct routes to privileged access on the Metasploitable 2 training VM. The most material results were root-level execution through the vsftpd backdoor and a network-exposed bind shell, passwordless root access over rlogin, database administrator-level access, and an accessible root graphical desktop through VNC. An NFS export also exposed the filesystem root to wildcard clients; a read-only mount from Kali succeeded.

The host is designed to be vulnerable. The severity labels are indicative of the risk if these conditions appeared on a real production host; they are not a CVSS environmental score.

Validated results at a glance

ID	Service / endpoint	Indicative risk	Observed result
F01	vsftpd backdoor (21/tcp)	Critical	Root command shell confirmed
F02	Exposed bind shell (1524/tcp)	Critical	Root shell confirmed
F03	rlogin (513/tcp)	Critical	Passwordless root login shown
F04	MySQL (3306/tcp)	Critical	Remote root; ALL PRIVILEGES shown
F05	PostgreSQL (5432/tcp)	High	Remote superuser role shown
F06	VNC (5900/tcp)	Critical	Root desktop confirmed
F07	NFS (111/2049)	High	Wildcard root export, read-only mount
F08	ProFTPD (2121/tcp)	Medium	Successful account login
F09	Tomcat Manager (8180/tcp)	Review	HTTP 200 and manager endpoint shown

Scope and constraints

The testing scope was limited to Metasploitable 2 network services on 192.168.107.165. Web application testing of DVWA is documented separately and is not included here. This report covers only services for which screenshots were supplied. It does not claim exhaustive coverage, persistence testing, data extraction, lateral movement, or exploitation of every detected version.

Evidence quality and interpretation

Screenshots show the command submitted and the resulting service, login, or privilege output. Where a credential was typed at an interactive prompt, the password itself is not visible. A successful login therefore proves access, but not necessarily an empty or default password. In particular, the MySQL screenshot does not independently prove that no password was supplied through a client configuration file.

2. Approach

DISCOVERY Identify service banners and open ports with Nmap; inspect target-side services where available.

VALIDATION Use the appropriate client (Metasploit, Netcat, rlogin, ftp, mysql, psql, VNC viewer, NFS utilities) to check access.

IMPACT Confirm effective identity using whoami/id or database privilege statements; avoid unnecessary changes.

REPORTING Use the original screenshots as exhibits and separate confirmed outcomes from configuration assumptions.

Read-only NFS mounting and identity queries were used where possible. The original screenshots are retained under their existing filenames. Screenshots are reproduced for context, including incidental background windows, without claiming those background pages are evidence for the primary test.

F01 Backdoored vsftpd provides a root shell

Priority / interpretation	Affected service	Evidence status
Critical	FTP 21/tcp; bind shell 6200/tcp	The session capture explicitly shows “Command shell session 1 opened” to 192.168.107.165:6200. The follow-on commands return root, uid=0(root), and hostname metasploitable.

Test performed

From Kali, the assessor configured a vsftpd backdoor Metasploit module against TCP/21 and obtained a command shell through the listener on TCP/6200. The visible module path ends in _fixed, indicating a modified/local module rather than evidence of an unchanged stock module.

What the evidence shows

The session capture explicitly shows “Command shell session 1 opened” to 192.168.107.165:6200. The follow-on commands return root, uid=0(root), and hostname metasploitable.

Assessment note. The association with CVE-2011-2523 is supported by the backdoor behavior. This finding is based on the successful shell, not on the version string alone.

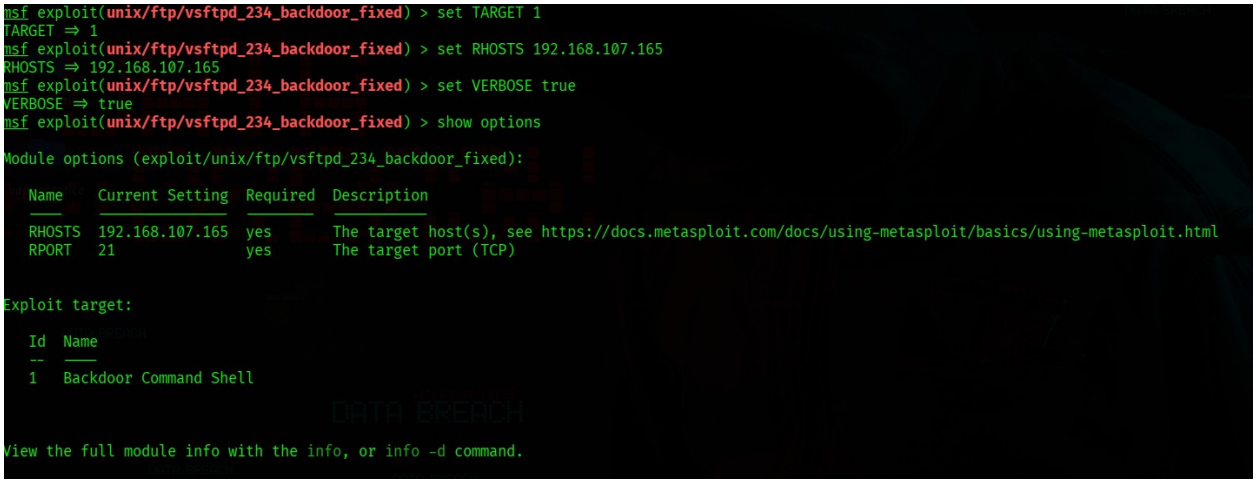
Security implication

The affected FTP build permits remote command execution with root privileges. On a non-lab asset this would represent full host compromise.

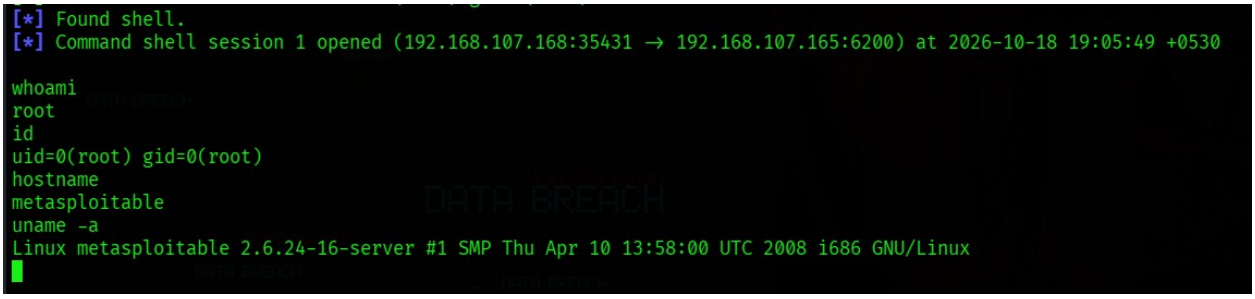
Recommended action

- Remove the compromised distribution and rebuild from trusted media or verified packages.
- Investigate unexpected listener activity and FTP access logs; restrict the network reachability of legacy FTP.

Supporting evidence



vsftpd1.png | *Exploit module target and configuration*



vsftpd2.png | *Opened shell and root user verification*

F02 Root bind shell is exposed on the network

Priority / interpretation	Affected service	Evidence status
Critical	TCP 1524	Nmap identifies TCP/1524 as “Metasploitable root shell”. A separate console view shows whoami returning root and id returning uid=0(root), gid=0(root).

Test performed

The assessor enumerated port 1524 with nmap -sV, connected to the available bind shell, and issued identity checks (whoami, id, hostname, pwd).

What the evidence shows

Nmap identifies TCP/1524 as “Metasploitable root shell”. A separate console view shows whoami returning root and id returning uid=0(root), gid=0(root).

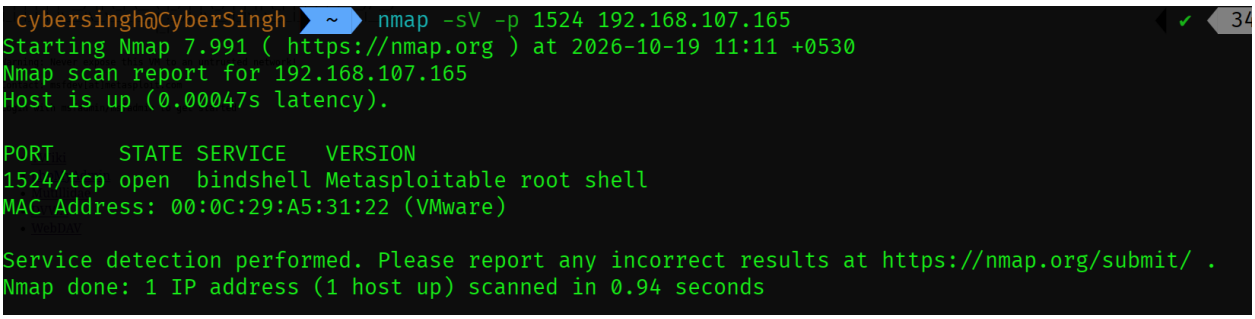
Security implication

The target exposes an interactive root-level command interface to any network party able to reach the listener.

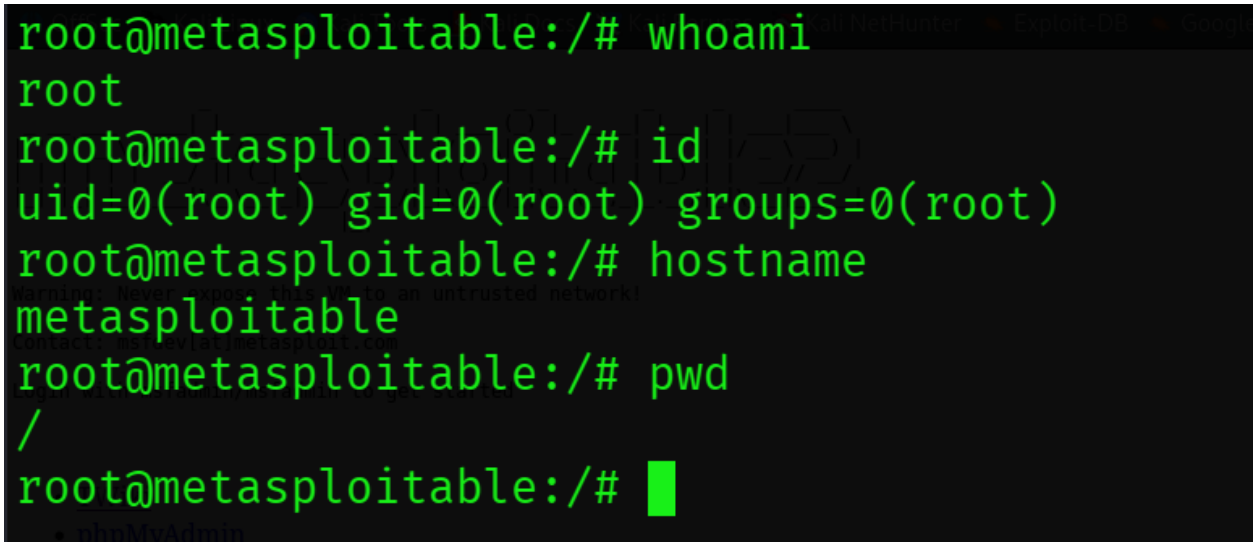
Recommended action

- Disable and remove the bind-shell service.
- Review system startup entries and network exposure; restrict administrative access to authenticated channels.

Supporting evidence



bindshell1.png | *Nmap identifies the bind-shell service*



blindshell2.png | Root shell identity and working directory

F03 Legacy rlogin grants passwordless root access

Priority / interpretation	Affected service	Evidence status
Critical	Rlogin TCP 513 (Rexec 512 and Rsh 514 exposed)	The rlogin connection opens a root terminal on metasploitable without a visible password prompt; whoami and id confirm uid=0(root). Nmap additionally identifies ports 512–514 as open.

Test performed

The assessor installed the supported legacy r-services client on Kali and used sudo rlogin -l root 192.168.107.165, then confirmed the resulting identity.

What the evidence shows

The rlogin connection opens a root terminal on metasploitable without a visible password prompt; whoami and id confirm uid=0(root). Nmap additionally identifies ports 512–514 as open.

Assessment note. The root rlogin path is demonstrated. The screenshots do not independently demonstrate a successful rexec or rsh command.

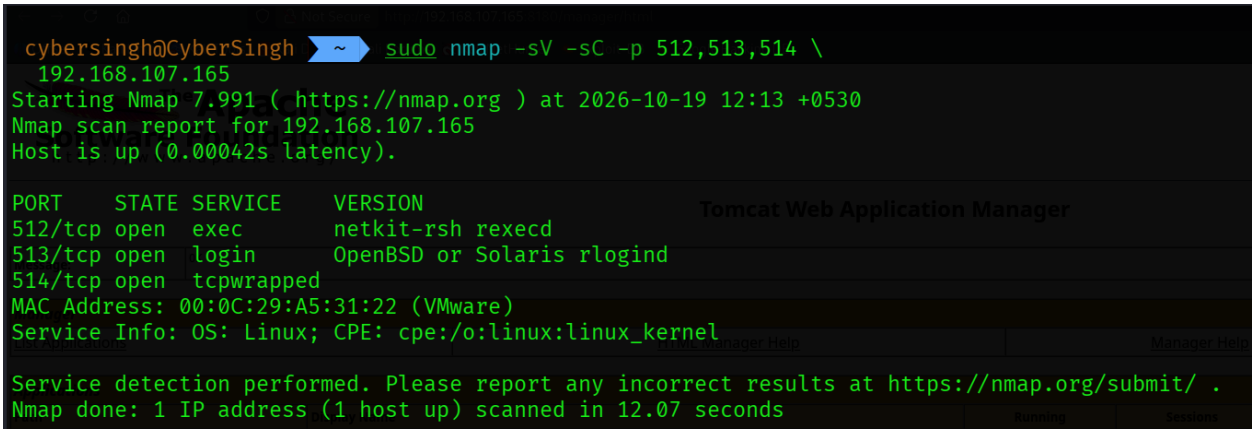
Security implication

Host-trust remote login without robust authentication exposes full operating-system control if reachable by an untrusted peer.

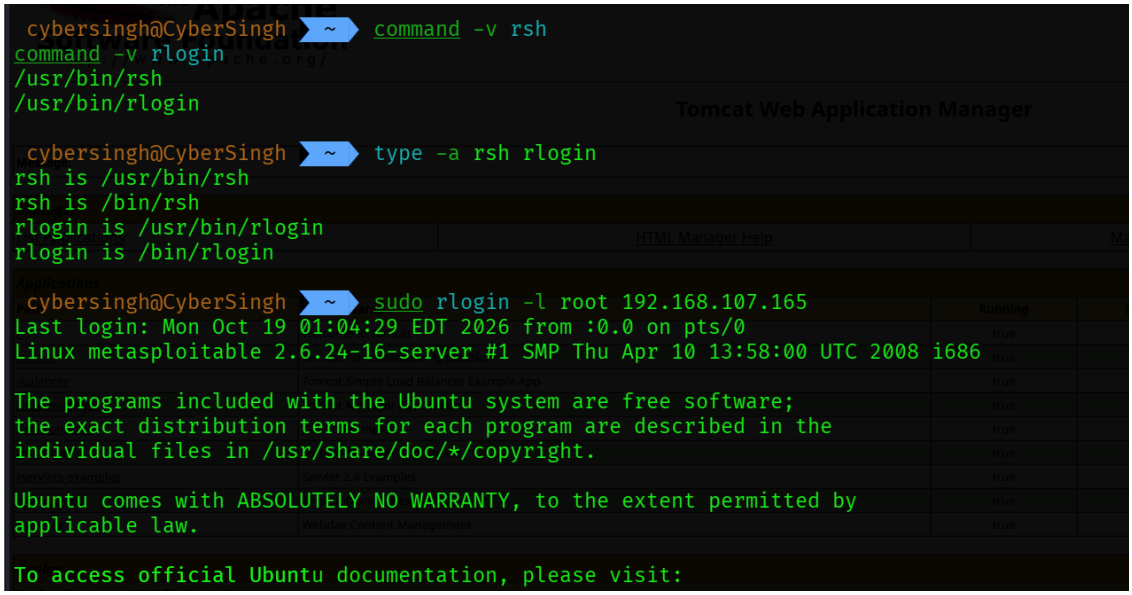
Recommended action

- Disable rlogin, rsh, and rexec; replace legitimate remote administration with SSH.
- Remove broad host-trust entries from .rhosts and hosts.equiv and review access records.

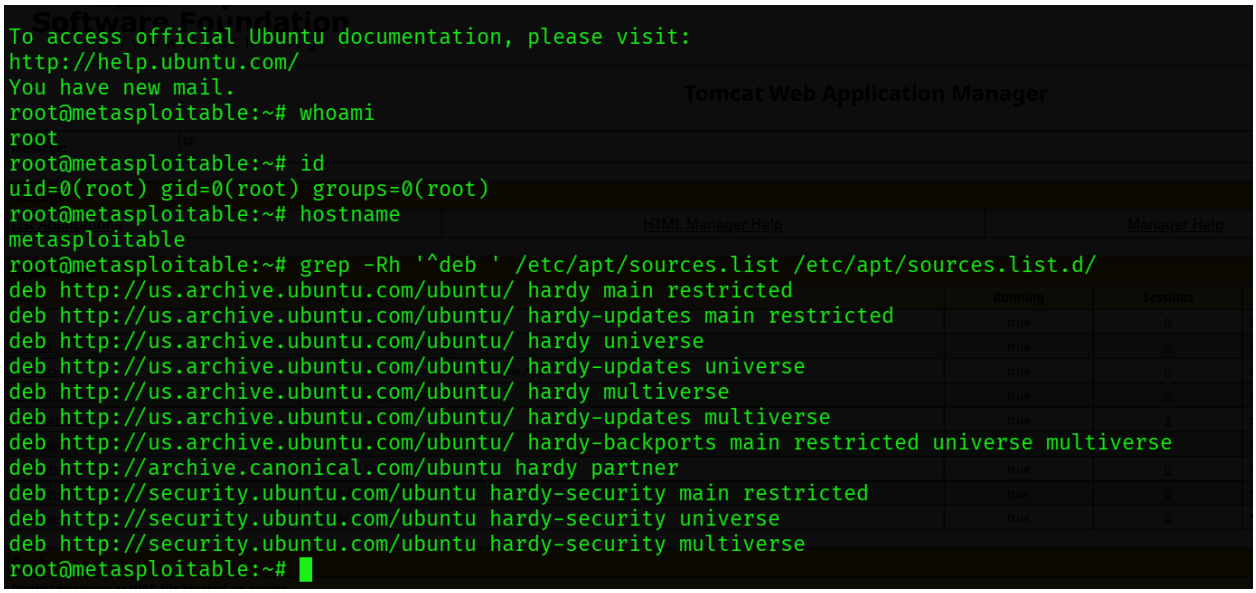
Supporting evidence



rservice.png | Discovery of TCP/512, 513 and 514



rservice2.png | *Remote root rlogin session*



rservice3.png | *Identity proof from root rlogin*

F04 Remote MySQL root account has unrestricted database privileges

Priority / interpretation	Affected service	Evidence status
Critical	MySQL TCP 3306	The MySQL client connected remotely as root@192.168.107.168; CURRENT_USER() returned root@%; SHOW GRANTS returned ALL PRIVILEGES ON *.* WITH GRANT OPTION. Several databases were listed.

Test performed

The assessor enumerated the MySQL service, connected using mysql -h 192.168.107.165 -P 3306 -u root --skip-ssl, and ran VERSION(), USER()/CURRENT_USER(), SHOW DATABASES, and SHOW GRANTS FOR CURRENT_USER().

What the evidence shows

The MySQL client connected remotely as root@192.168.107.168; CURRENT_USER() returned root@%; SHOW GRANTS returned ALL PRIVILEGES ON *.* WITH GRANT OPTION. Several databases were listed.

Assessment note. The evidence does not establish whether a password was empty or supplied implicitly by client configuration. Treat remote root access and broad grants as the proven issues.

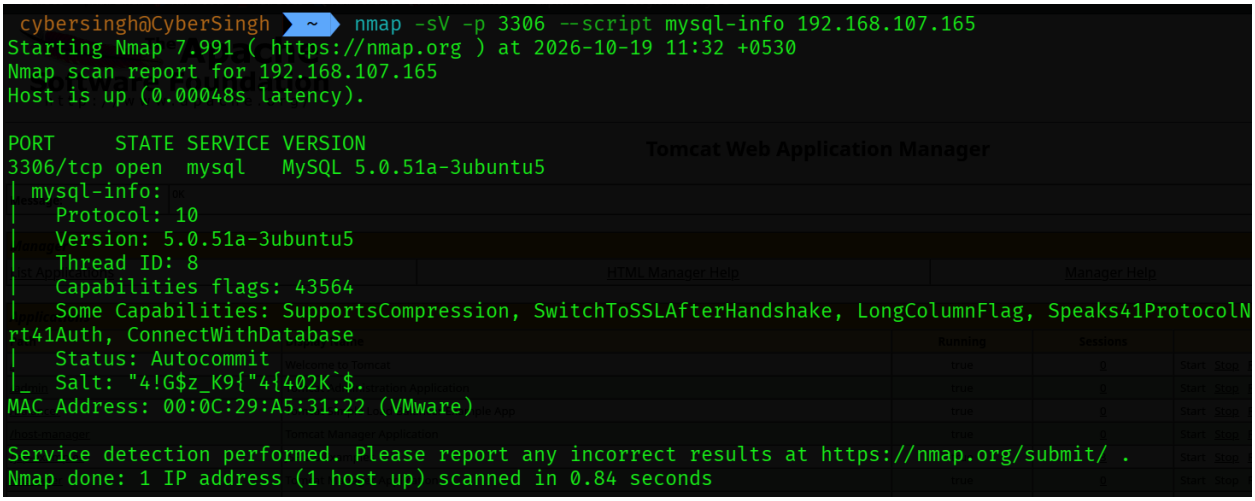
Security implication

Network-reachable MySQL administration with unrestricted grants permits database-wide reading and modification if accessed by an unauthorized actor.

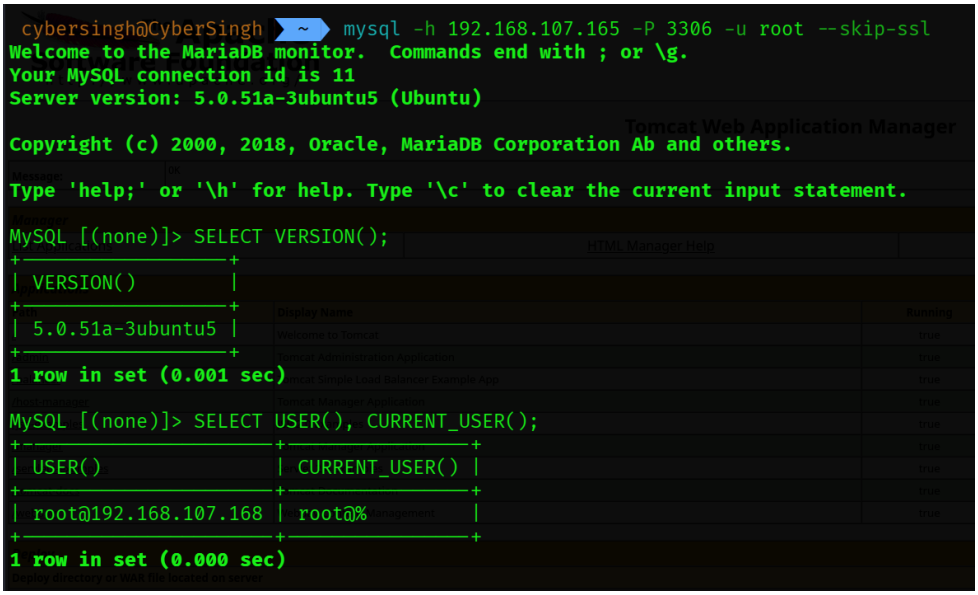
Recommended action

- Restrict root to local administration, remove root@% and grant only least-privilege accounts.
- Enforce strong authentication and TLS; firewall the database port to approved application or management hosts.

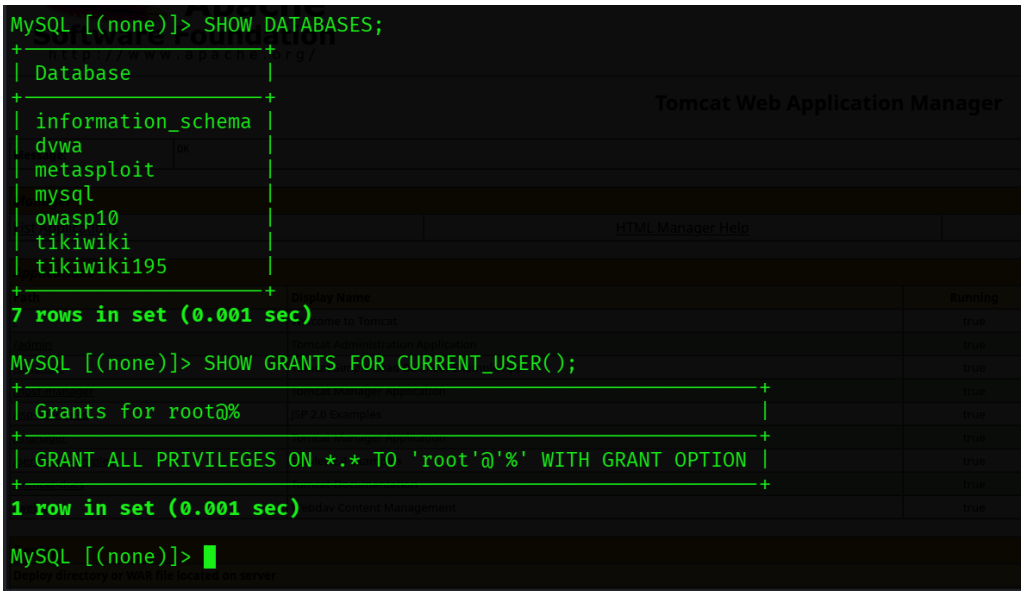
Supporting evidence



sql1.png | MySQL version and listener identified



sql3.png | *Remote MySQL root session identity*



sql4.png | *Databases and ALL PRIVILEGES grant*

F05 Remote PostgreSQL superuser authentication succeeds

Priority / interpretation	Affected service	Evidence status
High	PostgreSQL TCP 5432	A psql session to the target connects as postgres; a privilege query shows rolsuper=t and rolcanlogin=t. The target reports PostgreSQL 8.3.1.

Test performed

The assessor used psql -h 192.168.107.165 -p 5432 -U postgres -d template1 and ran read-only SELECT statements for version, session identity and pg_roles.

What the evidence shows

A psql session to the target connects as postgres; a privilege query shows rolsuper=t and rolcanlogin=t. The target reports PostgreSQL 8.3.1.

Assessment note. The screenshot displays a password prompt but not the entered value. A specific default-password claim requires separate authenticated evidence.

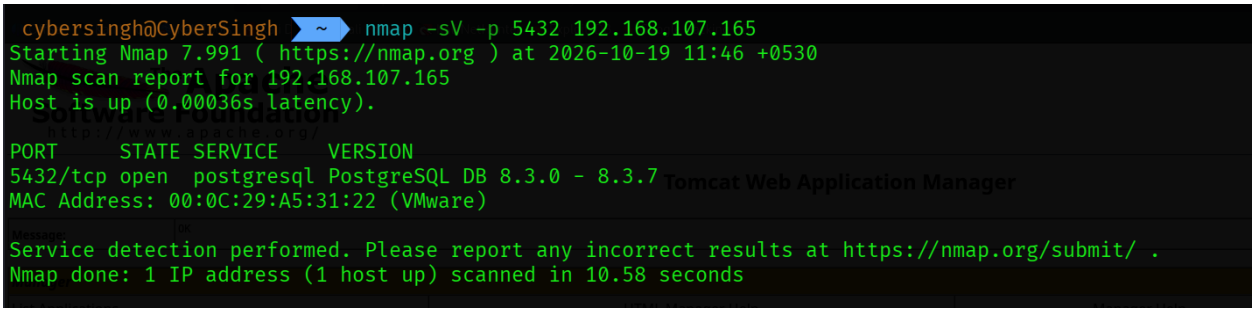
Security implication

A remotely accessible database superuser has extensive rights over the database instance and could compromise database integrity and confidentiality if credentials are abused.

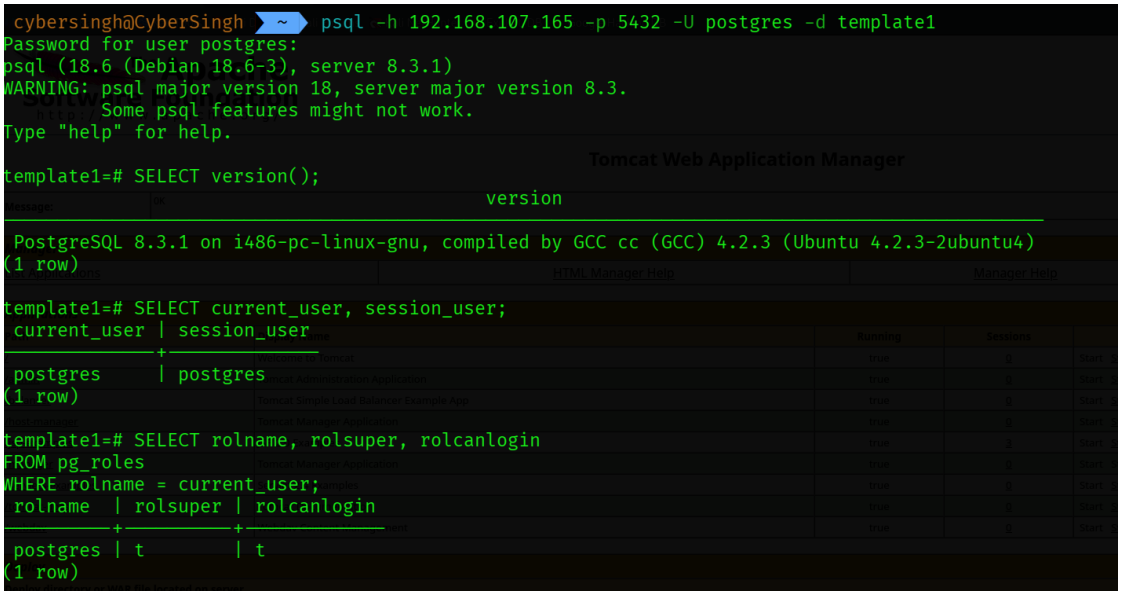
Recommended action

- Limit superuser access to trusted administration locations and use separate least-privilege application roles.
- Replace obsolete PostgreSQL releases; review pg_hba.conf and enforce appropriate authentication and transport security.

Supporting evidence



postgre1.png | *PostgreSQL exposed on 5432/tcp*



postgre2.png | *Remote authenticated role and rolsuper=t*

F06 VNC permits remote control of a root desktop

Priority / interpretation	Affected service	Evidence status
Critical	VNC TCP 5900	The VNC probe identifies protocol 3.3 and VNC Authentication. A TigerVNC screenshot shows the target desktop with a root terminal; whoami and id confirm root.

Test performed

The assessor enumerated the VNC service and connected using a VNC viewer. Within the remote desktop, the assessor executed whoami, id, and pwd.

What the evidence shows

The VNC probe identifies protocol 3.3 and VNC Authentication. A TigerVNC screenshot shows the target desktop with a root terminal; whoami and id confirm root.

Assessment note. The screenshot proves root desktop access; it does not show the actual VNC password or confirm the encryption properties of the negotiated session.

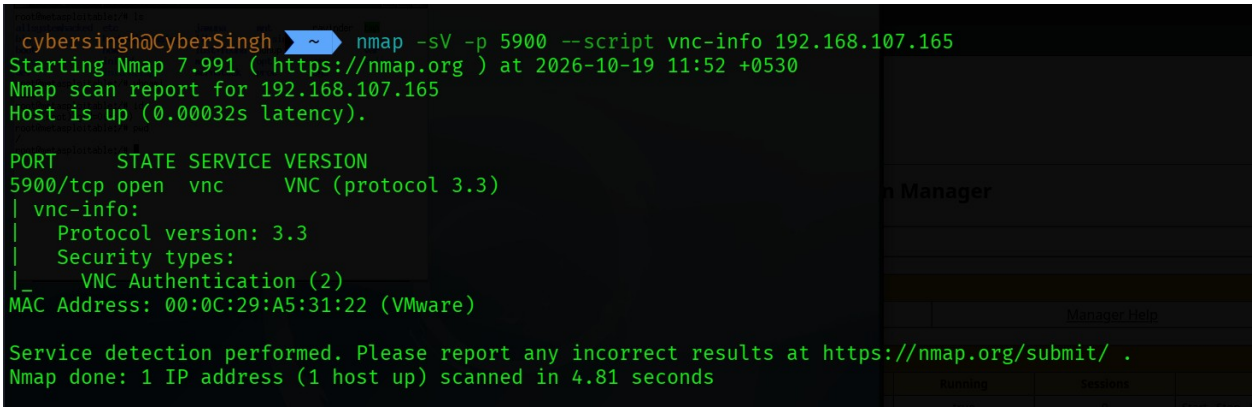
Security implication

Access to a root-owned graphical session gives an authenticated remote user unrestricted host control. Weak shared VNC credentials would make this especially dangerous.

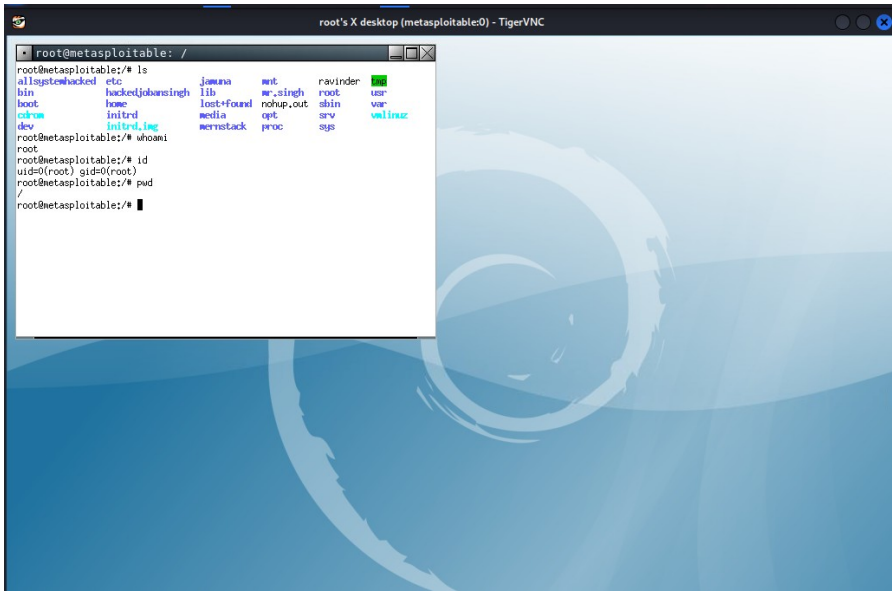
Recommended action

- Disable root-owned VNC sessions.
- Require unique strong authentication and restrict management access; use a secure tunnel or an encrypted remote-access service.

Supporting evidence



vnc1.png | VNC service, protocol and authentication type



vnc.png | Root terminal visible inside TigerVNC desktop

F07 NFS root filesystem is exported to wildcard clients

Priority / interpretation	Affected service	Evidence status
High	RPC TCP 111; NFS TCP 2049	showmount -e lists the root export as "/ *". Kali successfully mounted 192.168.107.165:/ at /mnt/metasploitable_nfs with ro,nolock,vers=3 and listed directory entries. The Nmap script displayed the root volume.

Test performed

The assessor enumerated RPC/NFS, checked exported paths with showmount -e, mounted the root export read-only, and listed its directory contents.

What the evidence shows

showmount -e lists the root export as "/ *". Kali successfully mounted 192.168.107.165:/ at /mnt/metasploitable_nfs with ro,nolock,vers=3 and listed directory entries. The Nmap script displayed the root volume.

Assessment note. The supplied evidence confirms the export and read access. It does not prove the NFS export allows writing or has no_root_squash enabled.

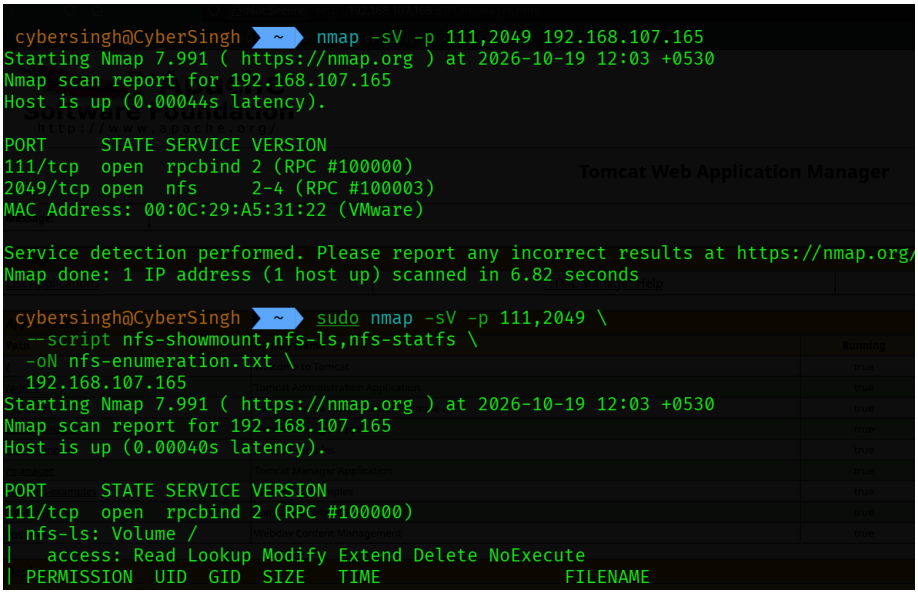
Security implication

A root filesystem export available to broad clients can expose internal directory contents. Write access or unsafe root mapping, if additionally configured, could increase the impact substantially.

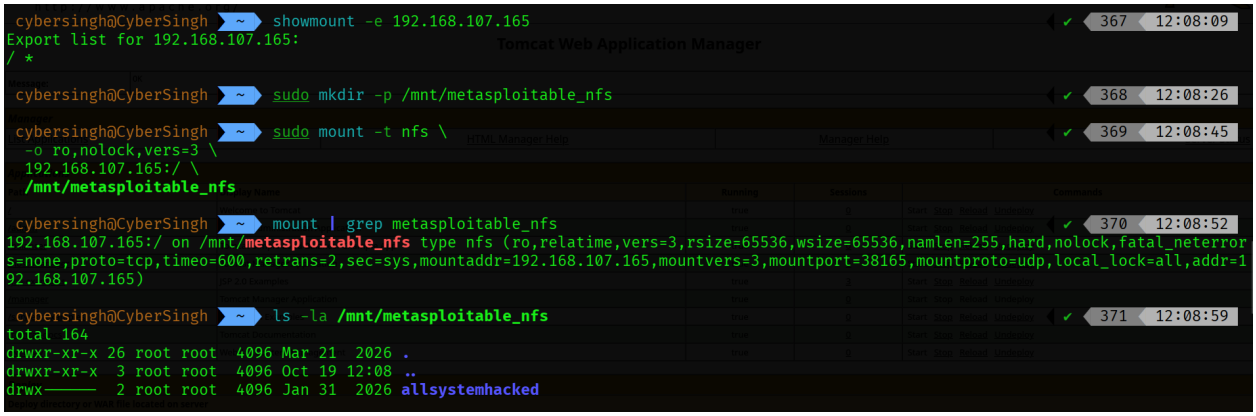
Recommended action

- Export only required subdirectories to named client IP ranges or networks.
- Use root_squash, avoid broad anonymous access, and explicitly restrict read/write permissions.

Supporting evidence



nfs.png | *RPC/NFS enumeration and export listing*



nfs2.png | Wildcard export, read-only NFS mount and file listing

F08 ProFTPD accepts an ordinary lab account

Priority / interpretation	Affected service	Evidence status
Medium	ProFTPD TCP 2121	The FTP session returns “230 User msfadmin logged in”; pwd returns /home/msfadmin; ls returns the vulnerable directory. Nmap identifies ProFTPD 1.3.1.

Test performed

The assessor connected with ftp 192.168.107.165 2121 and supplied account credentials for msfadmin, then inspected the working directory and listing.

What the evidence shows

The FTP session returns “230 User msfadmin logged in”; pwd returns /home/msfadmin; ls returns the vulnerable directory. Nmap identifies ProFTPD 1.3.1.

Assessment note. The screenshot confirms successful authentication but does not show which password was entered, or a packet capture proving a particular credential crossed the wire.

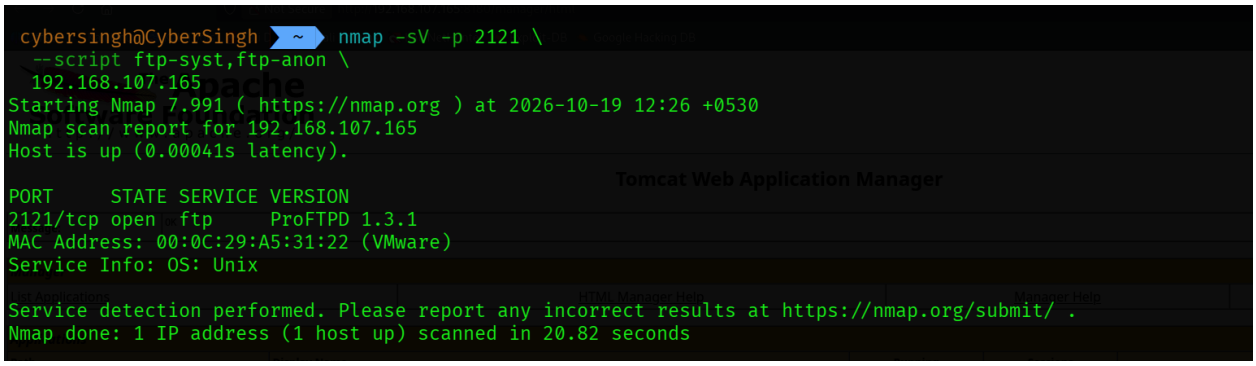
Security implication

FTP transmits usernames and passwords in plaintext unless explicitly protected with TLS. A known shared lab account on a network-exposed service weakens access control.

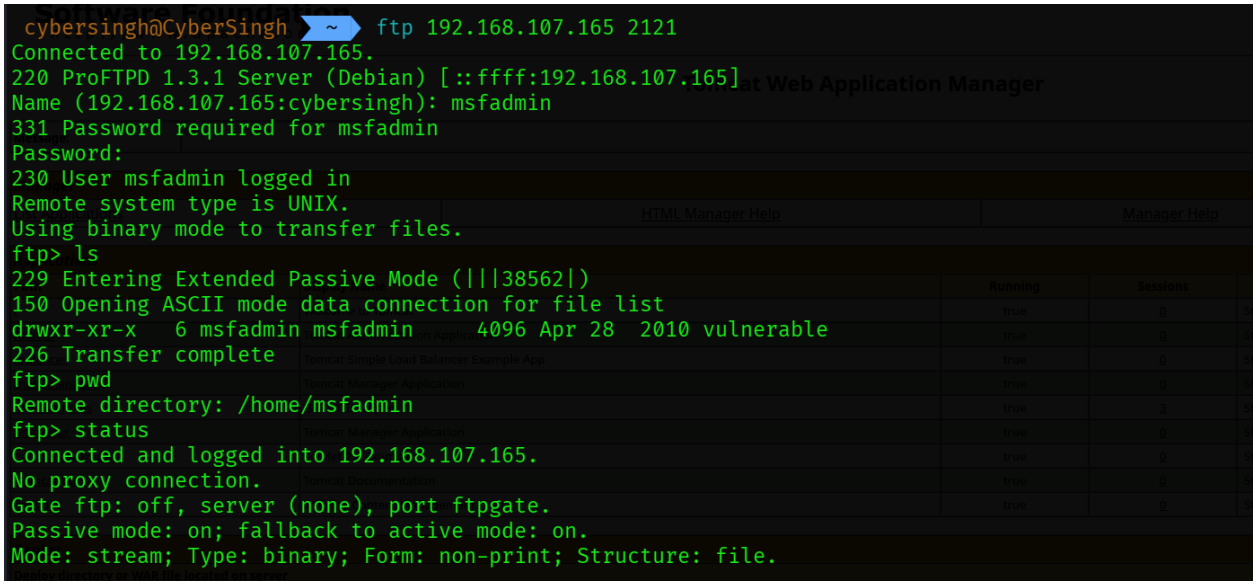
Recommended action

- Disable FTP where unnecessary; otherwise use SFTP or authenticated FTPS.
- Remove shared/default accounts, rotate credentials and limit user access to required directories.

Supporting evidence



proftpd.png | *ProFTPD 1.3.1 detected on TCP/2121*



proftpd2.png | Successful account login and directory listing

F09 Tomcat Manager endpoint responds over HTTP

Priority / interpretation	Affected service	Evidence status
Review	HTTP TCP 8180	Nmap identifies Apache Tomcat/5.5 and finds HTTP Basic authentication endpoints at /manager/html and /manager/status. A curl request to /manager/html returns HTTP 200. The browser background shows the Tomcat Manager interface.

Test performed

The assessor enumerated port 8180 with Nmap HTTP scripts and requested the manager HTML endpoint with curl, recording the HTTP status code.

What the evidence shows

Nmap identifies Apache Tomcat/5.5 and finds HTTP Basic authentication endpoints at /manager/html and /manager/status. A curl request to /manager/html returns HTTP 200. The browser background shows the Tomcat Manager interface.

Assessment note. HTTP 200 indicates that a page was returned, but the screenshot alone does not prove successful application deployment or unauthenticated administrative privileges.

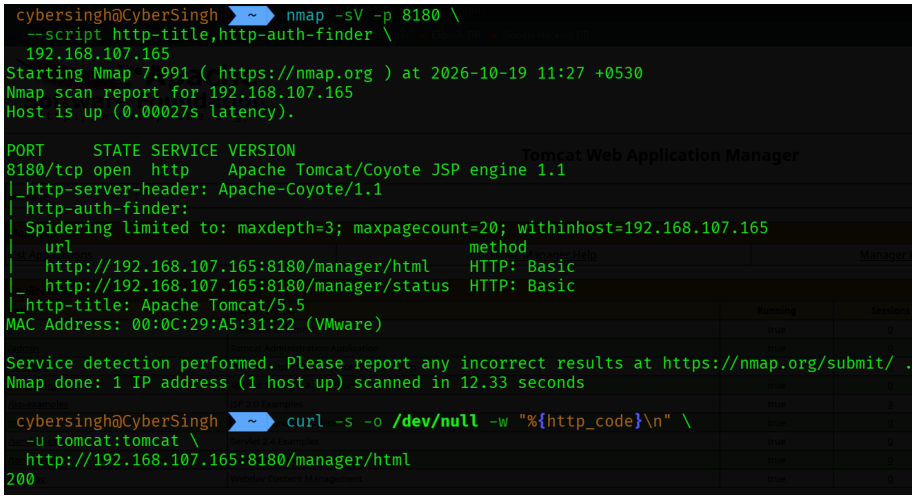
Security implication

Exposure of a manager endpoint enlarges the attack surface. Administrative deployment risk depends on whether the management functions are accessible without appropriate authorization.

Recommended action

- Restrict Tomcat Manager to trusted administrators and remove it if not required.
- Confirm authentication on the manager and its deployment functions, apply least-privilege roles and update the obsolete Tomcat version.

Supporting evidence



tomcat.png | Manager URL discovery and HTTP 200 response

3. Recommended remediation order

If these observations were made on a production host, the practical order of response would be:

Priority	Action	Why
Immediate	Remove exposed root command interfaces and isolate affected vsftpd	Direct OS-level root execution
Immediate	Disable passwordless root rlogin; restrict VNC	Root access from the network
High	Constrain MySQL root grants and PostgreSQL superuser access	Database-wide administrative rights
High	Restrict NFS exports to named hosts and subdirectories	Broad filesystem visibility
Planned	Remove or secure ProFTPD and Tomcat Manager	Unnecessary remote-facing legacy services
Follow-up	Retest each finding from an independent host	Show effective remediation

Suggested retest checklist

- Nmap no longer reports unintended TCP/1524, 513 or 5900 access.
- The FTP backdoor trigger no longer establishes a root shell.
- Database root/superuser roles cannot authenticate remotely except from approved hosts.
- showmount -e no longer lists a wildcard export of /.
- FTP and Tomcat Manager access follow an explicit access policy.

Assessment limitations

This was not a complete penetration test of all TCP and UDP services. The record is a reconstruction from submitted screenshots, not a full packet capture or raw terminal log. Exact credentials entered into interactive prompts and server configuration values were not supplied for several services. Severity should be recalibrated for a real asset using actual network segmentation, data sensitivity and business context.

4. Exhibit register

Finding	Original evidence screenshots
F01	vsftpd1.png; vsftpd2.png
F02	bindshell1.png; blindshell2.png
F03	rservice.png; rservice2.png; rservice3.png
F04	sql1.png; sql3.png; sql4.png
F05	postgre1.png; postgre2.png
F06	vnc1.png; vnc.png
F07	nfs.png; nfs2.png
F08	proftpd.png; proftpd2.png
F09	tomcat.png

Retain the original PNG files alongside this report. Screenshots are included for review and contextualised by each finding; separate raw scanner output and capture timestamps should be kept whenever available.

5. Reference material

MITRE CVE-2011-2523; Nmap service detection and NSE manuals; product documentation for MySQL account grants, PostgreSQL roles, NFS export options and Tomcat Manager access controls.